Apache HTTP Server · Path Traversal and RCE

CVE-2021-41773 | De-identified public edition | Published 2026-11-09

Record	Scope
Evidence	Observed in lab
Lab record date	2026-11-06
Environment	Apache HTTP Server 2.4.49 · Docker
Evidence scope	Command execution inside the test container
Patch verification	No patch retest recorded

Public summary: evidence is transcribed and de-identified. Original reports and screenshots are retained locally.

專題目標與範圍

這份專題記錄我在隔離實驗環境中，重現 Apache HTTP Server 2.4.49 的路徑處理弱點，以及啟用 CGI 並搭配特定目錄權限設定時的指令執行情境。實測紀錄日期為 2026 年 11 月 6 日，網站整理日期為 11 月 9 日。

測試服務位於 Kali Linux 上的 Docker 容器，透過本機映射連線。公開版本以元件名稱描述拓樸，移除原始位址、容器識別碼與個別主機資訊。以下為去識別化後的實測摘要，並非重新執行一次攻擊。

漏洞條件與實驗設計

Apache 官方公告 說明，此弱點與 2.4.49 的路徑正常化變更有關；目錄保護及 CGI 設定會影響實際結果。因此，專題同時記錄版本、模組與存取設定，而不是只憑版本號推論所有部署都能執行指令。

觀察項目	本次紀錄
元件	Docker 中的 Apache HTTP Server 2.4.49
基本服務	首頁可正常回應
普通路徑請求	記錄到 404
編碼路徑請求	記錄到 403
CGI 情境	指令回應包含程序身分資訊

實測證據摘要

本機截圖與終端紀錄保留了兩個身分檢查的回應。下列僅轉錄結果，省略請求位址與利用參數：

```
id
uid=0(root) gid=0(root) groups=0(root)

whoami
root
```

這些輸出支持「測試容器內已發生指令執行」，並顯示該程序以容器內 root 身分運作。它們不代表已取得 Kali 宿主機或 VMware 宿主機控制權，也沒有證明容器逃逸。

如何解讀 404 與 403

原始紀錄將兩種狀態碼差異列為路徑測試結果。重新整理時，我將它們保留為觀察值，不把 403 單獨當成任意檔案讀取成功的證據；404 也不足以定位是哪一層完成正常化。客戶端、代理與伺服器都可能改變路徑，必須與請求處理及實際回應一起分析。

這個區分讓報告的結論依賴可觀察結果，而不是把某個 HTTP 狀態碼直接翻譯成「漏洞成功」。

修補方向與後續複測

Apache 的歷史修補也有值得記錄的地方：2.4.50 對本 CVE 的修正仍有不足，後續另以 CVE-2021-42013 追蹤，於 2.4.51 修復。維運時應使用仍受支援且包含相關修補的版本，並檢查不必要的 CGI 與過度寬鬆的目錄設定。官方修補紀錄

目前資料沒有修補後同條件複測的結果。後續可用相同請求與觀察方法，比較更新前後的服務回應、存取限制及程序權限，將修補建議進一步轉為可驗證的對照實驗。